CARTILHA

PHISHING
O famoso e malicioso “clique aqui”



Autora: Mariana Freire Cosentino

MASCARELLO HAUS
CONSULTORIA E ASSESSORIA JURÍDICA

PHISHING O FAMOSO E MALICIOSO "CLIQUE AQUI"

AUTORA:
MARIANA FREIRE COSENTINO

REVISÃO TÉCNICA:
MIRATAIRA HAUS

PROJETO GRÁFICO:
TEMPERO PROPAGANDA



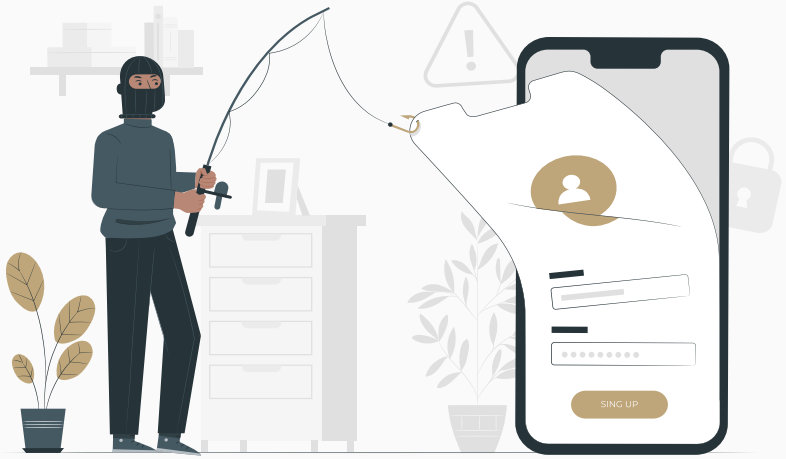
O que você vai entender com esta cartilha:

- O que é o *phishing*, como funciona;
- Orientações para não ser pego nesse tipo de golpe.

O que é?

Phishing é um cibercrime que consiste em enganar as pessoas de modo a levá-las a fornecerem diretamente dados pessoais e informações confidenciais como senhas e número de cartões de crédito ou, ainda, a clicarem em links ou arquivos para download que acreditam serem confiáveis, permitindo que um programa malicioso funcione na máquina e colete as informações da vítima (o denominado "*malware*").

Pelo *phishing,* os criminosos não precisam "arrombar nenhuma porta de segurança", pois enganam as pessoas, levando-as a entregarem a própria chave para abri-la. As campanhas de *phishing* podem ser por e-mails, ligações ou mensagens de texto, enviadas em massa ou para algum alvo específico.



Vem do termo da língua inglesa "*fishing*", que significa "pescaria". A analogia remete a um pescador jogando um anzol com isca, que fica esperando que a vítima a morda.

Um ataque de *phishing* bem-sucedido pode ter sérias consequências: no âmbito pessoal, desde o roubo de dinheiro, cobranças fraudulentas em cartões de crédito, perda de acesso a fotos, vídeos e arquivos, e até roubo de identidade para fins ilícitos: no âmbito profissional, há riscos de exposição

de informações pessoais de clientes e colegas de trabalho, roubo de arquivos confidenciais ou inacessibilidade, sem mencionar irreparáveis danos à reputação da empresa.

Como funciona ?

A tática mais comum é enviar um e-mail ou uma mensagem de texto a potenciais vítimas, com todo o aspecto de "oficial", fazendo-se passar por um banco, Correios, órgão governamental, empresa privada ou mesmo uma pessoa conhecida.



O envio de e-mails consiste em mensagens falsas relacionadas a bancos ou instituições, que levam o destinatário a fornecer seus dados pessoais. O mesmo e-mail é enviado para milhares de pessoas.

As mensagens geralmente têm um tom alarmista, que amedronta a pessoa e a induz a deixar o senso crítico de lado. Os atacantes maliciosos preparam as "iscas" para as vítimas fornecerem seus dados ou clicarem em um link, que costuma ser uma imitação bem feita de um website legítimo.

A mensagem de *phishing* exige que a vítima execute uma ação imediata, concedendo as informações sigilosas, ou acesse um website para conceder as informações, ou ainda faça o login com nome de usuário e senha. Assim, a pessoa concede seus dados pessoais, e tais informações são utilizadas por criminosos para roubo de identidades, contas bancárias e comercialização de tais informações no mercado ilegal.

Quando se utilizam do **medo** para enganar, as mensagens pedem para que as pessoas atualizem, confirmem ou alterem números de cartões de crédito, senhas e dados de contas, ameaçando que a conta será encerrada caso tais medidas não sejam imediatamente tomadas. Ou ainda, informam que foram detectadas atividades suspeitas na sua conta, sendo necessário confirmar suas informações e impedir o ataque. O mais impressionante é que os atacantes nos enganam justificando que tais ações seriam para a própria segurança das informações e contas das pessoas.



As mensagens também podem gerar um **desejo** nas pessoas, especialmente de receber dinheiro, oferta, promoção, desconto, sorteio, prêmio ou qualquer item interessante.



Tipos de *Phishing*

1. *Clone phishing*: os criminosos copiam um e-mail legítimo recebido anteriormente que contenha um link ou um anexo, substituindo os links ou arquivos anexos por conteúdo malicioso.

2. *Phone* ou *SMS phishing*: nesse caso, a vítima recebe uma ligação de alguém se dizendo representar uma empresa, instituição ou até órgão público, relatando algum problema ou oferecendo algo bom. Para resolver o problema ou aproveitar a oportunidade, convence a pessoa a fornecer dados da sua conta, pagar um boleto enviado referente a uma taxa, fazer um Pix, transferência, etc. Existe também o envio de links maliciosos por mensagens SMS.

Identificando um ataque

Os criminosos criam páginas, links, anexos e até aplicativos falsos e maliciosos. Eles se passam por grandes lojas, bancos, redes sociais, comércios eletrônicos variados e até órgãos públicos. Podem ser muito convincentes e fazem de tudo para o aspecto das mensagens não levantar suspeitas: utilizam os mesmos logotipos da empresa, mesma fonte, cores, slogan e diagramação, tudo para dar mais veracidade. Além disso, utilizam uma linguagem formal e comandos claros típicos das organizações, ou seja, parecem totalmente profissionais.

Ao direcionar para formulários para o preenchimento de informações, parece que tais formulários são oficiais, porque são extremamente bem feitos. No entanto, temos que ter sempre em mente que apenas os próprios websites oficiais oferecem um ambiente seguro para passarmos nossos dados.



Quando se trata de e-mail, pode até ser de um remetente conhecido, mas se está pedindo informações demais e, geralmente, você nunca recebeu um desse tipo, desconfie! Tanto instituições privadas e governamentais quanto bancos e empresas **não** pedem dados pessoais de seus clientes por e-mail ou mensagens, e **não** pedem para confirmar ou alterar senhas (a não ser que você tenha pedido por ter se esquecido).

Os remetentes parecem ser oficiais, mas contém erros sutis de digitação, ou têm uma grande extensão de caracteres, com muitos números e abreviações. ("noreply@google-49msom-nfj2390ddsdjfn02948820- fm", por exemplo). Dificilmente um e-mail legítimo de grandes empresas conterá erros ortográficos ou de gramática. **No entanto, o fato de os remetentes conterem o nome da empresa não significa que realmente sejam um veículo oficial de comunicação!**

A mensagem maliciosa cria alguma situação negativa ("sua conta foi acessada por terceiros", por exemplo) e, com uma falsa urgência, induz você a fazer algo imediatamente para tentar reverter ("se você clicar aqui agora/nas próximas 24 horas/hoje, poderá ter sua conta preservada", por exemplo). Criar uma falsa percepção de necessidade é um truque comum, porque realmente funciona.

A mensagem contém anexos curiosos. Se forem boletos para pagamento, desconfie imediatamente.



“Eu não caio em *phishing*!”

1. Nunca clique em um link que esteja em um e-mail, a menos que você conheça muito bem quem mandou e exista um CONTEXTO que justifique o porquê de estar recebendo aquele e-mail (exemplo: envio de confirmação de compra, status do pedido, código de rastreio, etc). Caso contrário, desconfie até mesmo de mensagens enviadas por pessoas e sites conhecidos.

2. Suspeite de mensagens com temas cotidianos, como cancelamento de contas, débitos em atraso, recadastramento de senhas, ofertas de emprego e dinheiro fácil e, resgate de pontos a vencer. A criatividade dos criminosos é extensa, eles podem criar histórias e situações bastante possíveis.

3. Nunca forneça senhas ou códigos de verificação por meio de mensagens de e-mail ou celular.

4. Sempre que possível, ative a verificação em 2 etapas.



5. Nas redes sociais: ao contatar serviços de atendimento ao cliente, verifique se é o perfil oficial pelo selo de “conta verificada”, quando disponível, ou por outros meios (ligando para os canais de atendimento, por exemplo).



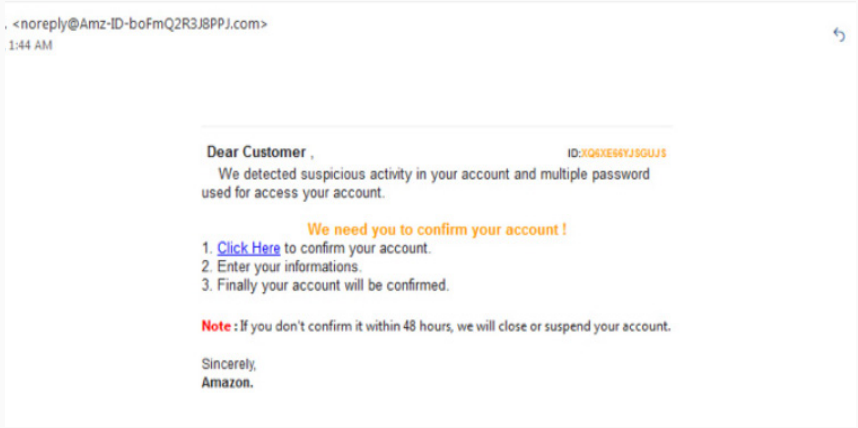
6. Acesse os sites das empresas digitando o endereço URL diretamente no navegador ou, se usar sites de busca, verifique se a URL é a oficial.

7. Instale apenas aplicativos oficiais da própria instituição.

8. Use sempre conexão segura: verifique se a URL da página começa com “httpS” e não apenas como “http”. O "S" significa “*safe*” (seguro). Isso ainda não é uma garantia de que o site seja seguro, mas é mais provável que seja.

9. Passe o mouse sobre os links disponíveis para ver se as URLs são legítimas e parecem ser oficiais. Se for um endereço estranho, não clique.

Exemplos de ataques



O que tem de errado no e-mail acima?

- Observe o e-mail remetente duvidoso: noreply@Amz-ID-boFmQ2R3J8PPJ.com.
- Endereçamento genérico à pessoa ("Dear Customer", "Caro Cliente").
- Há uma ameaça típica de encerrar a conta se nada for feito em 48 horas (*"if you don't confirm it within 48 hours, we will close or suspend your account"*). Isso é típico de *phishing*!

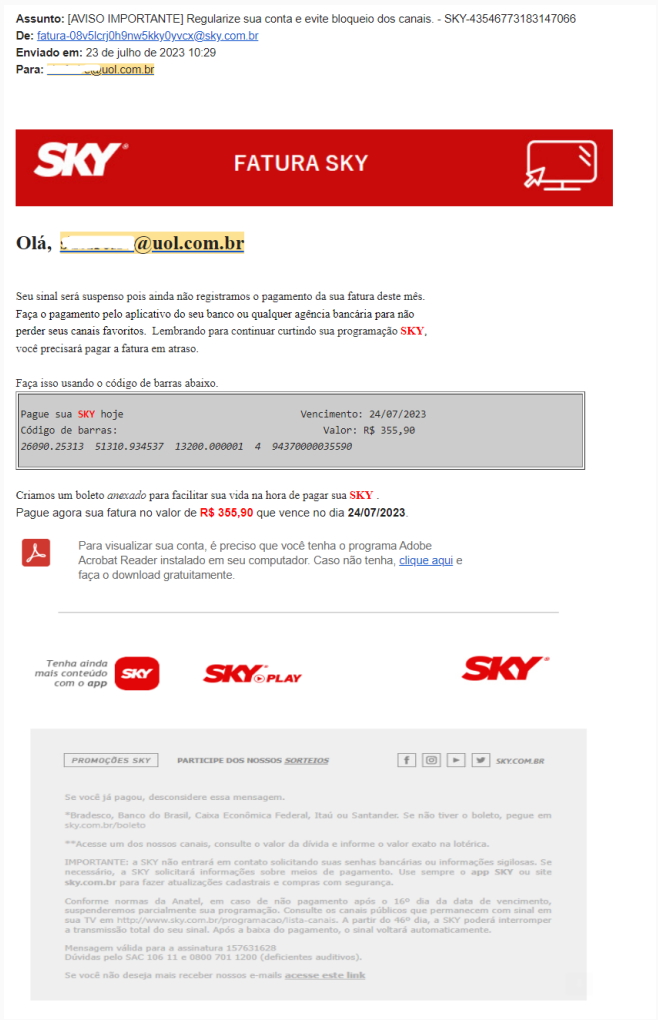
Agora um exemplo de um e-mail oficial de confirmação de envio de um item: aspecto profissional; nome do cliente; links todos do próprio site da Amazon; dentro de um contexto de uma compra realizada; remetente legítimo: shipment-tracking@amazon.com.br





Mais um exemplo de *phishing*, observe os pontos de atenção!

- Remetente totalmente duvidoso: fatura-08v5lcrj0h9nw5kky0yvcx@sky.com.br.
- Endereçamento “Olá, [e-mail da pessoa]”.
- Envio de um boleto para pagamento .
- Há uma ameaça: “para não perder seus canais favoritos”, e também um erro de gramática: “Lembrando para continuar curtindo”.



Assunto: [AVISO IMPORTANTE] Regularize sua conta e evite bloqueio dos canais. - SKY-43546773183147066
De: fatura-08v5lcrj0h9nw5kky0yvcx@sky.com.br
Enviado em: 23 de julho de 2023 10:29
Para: [redacted]@uol.com.br

SKY FATURA SKY

Olá, [redacted]@uol.com.br

Seu sinal será suspenso pois ainda não registramos o pagamento da sua fatura deste mês.
Faça o pagamento pelo aplicativo do seu banco ou qualquer agência bancária para não perder seus canais favoritos. Lembrando para continuar curtindo sua programação SKY, você precisará pagar a fatura em atraso.

Faça isso usando o código de barras abaixo.

Pague sua SKY hoje — Vencimento: 24/07/2023
Código de barras: — Valor: R$ 355,90
26090.25313 51310.934537 13200.000001 4 94370000035590

Criamos um boleto *anexado* para facilitar sua vida na hora de pagar sua SKY .
Pague agora sua fatura no valor de R$ 355,90 que vence no dia 24/07/2023.

Para visualizar sua conta, é preciso que você tenha o programa Adobe Acrobat Reader instalado em seu computador. Caso não tenha, clique aqui e faça o download gratuitamente.

Tenha ainda mais conteúdo com o app SKY — SKY PLAY — SKY

PROMOÇÕES SKY — PARTICIPE DOS NOSSOS SORTEIOS — SKY.COM.BR

Se você já pagou, desconsidere essa mensagem.

*Bradesco, Banco do Brasil, Caixa Econômica Federal, Itaú ou Santander. Se não tiver o boleto, pegue em sky.com.br/boleto

**Acesse um dos nossos canais, consulte o valor da dívida e informe o valor exato na lotérica.

IMPORTANTE: a SKY não entrará em contato solicitando suas senhas bancárias ou informações sigilosas. Se necessário, a SKY solicitará informações sobre meios de pagamento. Use sempre o app SKY ou site sky.com.br para fazer atualizações cadastrais e compras com segurança.

Conforme normas da Anatel, em caso de não pagamento após o 16º dia da data de vencimento, suspenderemos parcialmente sua programação. Consulte os canais públicos que permanecem com sinal em sua TV em http://www.sky.com.br/programacao/lista-canais. A partir do 46º dia, a SKY poderá interromper a transmissão total do seu sinal. Após a baixa do pagamento, o sinal voltará automaticamente.

Mensagem válida para a assinatura 157631628
Dúvidas pelo SAC 106 11 e 0800 701 1200 (deficientes auditivos).

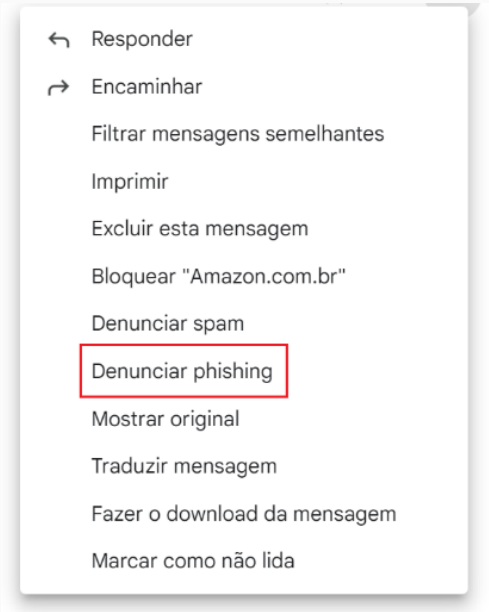
Se você não deseja mais receber nossos e-mails acesse este link

“Tem cheiro de *phishing*” – dicas rápidas para evitar esse tipo de golpe:

- Veja a saudação da mensagem: se endereçar a você de forma genérica, como "Caro cliente", em vez de usar seu nome, cuidado! Provavelmente é fraudulento, porque foi enviado a diversas pessoas.
- Antes de clicar em algum link, passe o mouse sobre hiperlinks e verifique se parecem ser do site oficial.
- Atente-se para a assinatura: veja as informações de contato no rodapé do e-mail, pois remetentes legítimos sempre as incluem e os maliciosos não costumam se preocupar com isso.
- Atenção ao tom do e-mail, se for alarmista ou oferecer algo “imperdível”, muito provavelmente é *phishing*!

Denuncie um ataque

Se você receber uma mensagem suspeita em sua caixa de entrada de e-mail, é possível clicar na opção “Denunciar *Phishing*”. Desse modo, você removerá a mensagem da sua caixa de entrada e fará a denúncia.



Para mais detalhes sobre esse e outros assuntos relacionados com cuidados com os dados pessoais na Internet, consulte os demais materiais disponíveis no site do escritório Mascarello Haus. A plataforma apresenta uma série de materiais focados nas empresas e nas diversas partes interessadas.



Mariana Freire Cosentino
Advogada e Consultora LGPD | Privacidade e Proteção de dados pessoais | Direito Digital.



Miratáira Haus
Advogada, Professora e Consultora | Esp. em Direito Digital e Compliance, Direito do Trabalho e Previdenciário | DPO Certificada EXIN.

Mascarello Haus

A Mascarello Haus Advocacia e Consultoria Jurídica, desde de 2016, presta serviços consultivos e de assessoramento nas áreas do Direito Civil, Empresarial, do Trabalho e Previdenciário.

Atualmente, é um escritório dedicado a entender às necessidades e riscos, em fomento da conformidade e boas práticas relacionadas a regulação do mercado, direcionado ao Compliance nas mais diversas áreas, em especial à Proteção de Dados. Por meio de equipe multidisciplinar, orienta e desenvolve estratégias que atendam aspectos regulamentares, de governança corporativa e de segurança da informação, em respeito à metodologia aplicável a cada segmento.

De maneira proativa também atua nas organizações da sociedade civil em projetos sociais e Advocacia Pro Bono.

MASCARELLO HAUS
CONSULTORIA E ASSESSORIA JURÍDICA

mascarellohaus.adv.br

mascarellohausadvocacia

49 98822 0982

contato@mascarellohaus.adv.br

Rua Coronel Alberto Schmidt, 10 • Edifício Laura, 1º Andar, Sala 5 • Centro • Videira • SC